# Cahier des charges de la plateforme Kiosy

## *Catalogue de contenus et abonnements avec assistant multi agent et serveurs MCP*

Version 1.0 • 30 septembre 2026

Document préparé pour Sandaniaina Tsinjo Nantosoa

Statut : référence de conception proposée, à valider avant lancement commercial.

Ce cahier des charges définit une plateforme de contenus numériques inspirée du parcours catalogue et abonnement de Viapresse, sans reprendre sa marque, ses contenus ni présumer de son architecture interne. Le nom Kiosy et le nom de l'assistant KIA sont provisoires ; leur disponibilité reste à vérifier.

Le produit réunit presse, business et culture dans un catalogue, un espace lecteur et un espace éditeur. Un assistant unique accompagne les utilisateurs et coordonne des spécialistes capables de rechercher des informations, comparer des offres et préparer des opérations via MCP. Les règles métier, permissions, prix et droits d'accès sont appliqués par le backend.

Le projet doit fonctionner sans Odoo et sans dépendance à un ordinateur personnel : React sur Vercel, API Python sur Render, données et fichiers dans des services persistants. Il doit constituer une réalisation technique vérifiable et pouvoir évoluer vers un pilote commercial.

Le périmètre initial privilégie les contenus numériques et trois parcours complets : découverte et achat, gestion d'abonnement, résolution d'un problème d'accès. La diffusion commerciale dépendra de droits éditoriaux documentés, d'un prestataire de paiement accessible à la structure porteuse et de conditions contractuelles validées.

Les délais, budgets et indicateurs de ce document sont des hypothèses de planification ou des objectifs de recette. Ils ne constituent ni des résultats mesurés ni une promesse de revenu ou de conformité.

Livrables associés : document Word modifiable et version PDF de référence. Toute modification du périmètre doit être reportée dans une nouvelle version et reliée aux exigences concernées.

# 1 Guide de lecture et décisions de cadrage

## Structure du document

| Partie | Sections | Objet |
|---|---|---|
| Produit | 2 à 9 | Objectifs, rôles, catalogue, offres, abonnements, paiements et concurrence |
| Expérience et intelligence | 10 à 15 | Interfaces, agents, contrats MCP et recherche documentaire |
| Réalisation | 16 à 21 | Données, API, sécurité, déploiement, exploitation et objectifs |
| Validation et évolution | 22 à 27 | Tests, plan de livraison, extensions, budget, recette et références |

## Priorités et versions

P0 désigne une exigence indispensable au MVP démontrable. P1 correspond au pilote avec utilisateurs réels. P2 désigne une extension commerciale ou fonctionnelle. Une exigence P1 devient bloquante dès qu'un pilote utilise la fonction concernée ; un paiement réel ne peut donc pas être ajouté avant les protections prévues pour ce paiement.

Chaque exigence porte un identifiant stable. Les tickets de développement, tests et demandes de modification doivent citer cet identifiant. Les exemples de valeurs sont configurables lorsqu'ils sont présentés comme tels ; les invariants de sécurité et d'intégrité sont obligatoires.

## Décisions proposées

- D01 : démarrer avec presse, business et culture ; gratuit, achat à l'unité et abonnement thématique.
- D02 : proposer des PDF et textes en français au MVP ; stocker la langue dès le départ. Audio et interface malgache suivent en P1/P2.
- D03 : gérer plusieurs éditeurs dans le modèle et les tests, mais confier la publication à l'administration au MVP.
- D04 : disposer d'un coordinateur et de trois agents spécialisés au MVP ; activer un quatrième spécialiste d'assistance en P1.
- D05 : retenir trois serveurs MCP logiques et un monolithe backend modulaire. Aucun microservice métier supplémentaire sans besoin mesuré.
- D06 : utiliser un paiement de test au MVP ; une souscription mensuelle est renouvelée manuellement au départ. Le renouvellement automatique exige un prestataire compatible.
- D07 : interdire les paiements, remboursements et modifications de droits directement décidés par un LLM.

## Gouvernance

Le porteur du projet valide les objectifs et règles commerciales. Le développeur tient les décisions d'architecture et le registre des changements. Un responsable éditorial valide les contenus. Avant monétisation, un professionnel compétent valide les contrats, le traitement des données et les obligations applicables aux territoires servis.

# 2 Vision et objectifs mesurables

## Problème et proposition de valeur

La plateforme cherche à simplifier la découverte et la gestion de contenus provenant de plusieurs éditeurs. Le lecteur doit comprendre ce qui est inclus dans une offre, éviter un achat inutile et obtenir une réponse sur son accès sans naviguer entre plusieurs services. Cette proposition est une hypothèse produit à confirmer par des entretiens ; l'absence de concurrence locale n'est pas présumée.

Les publics envisagés sont les lecteurs à Madagascar, la diaspora et, ultérieurement, des organisations souhaitant fournir des accès individuels. Les partenaires éditoriaux restent propriétaires de leurs contenus selon les contrats signés. Le catalogue ne doit pas être constitué par copie non autorisée de sites ou publications.

## Objectifs de la première livraison

| ID | Priorité | Exigence et preuve attendue |
|---|---|---|
| OBJ01 | P0 | Un lecteur trouve une publication, consulte l'offre et termine un achat de test sans intervention technique. |
| OBJ02 | P0 | Un abonnement confirmé ouvre exactement les contenus inclus et refuse les autres. |
| OBJ03 | P0 | Une demande composée mobilise au moins deux spécialistes dont les résultats contribuent à la réponse finale. |
| OBJ04 | P0 | Les outils métier passent par de vrais échanges MCP observables, avec contrats et erreurs structurés. |
| OBJ05 | P0 | Une mutation sensible n'est exécutée qu'après confirmation autorisée et revalidation côté serveur. |
| OBJ06 | P1 | Un pilote mesure les parcours terminés, erreurs, demandes d'assistance et coûts IA sur une période définie. |

## Validation du besoin

Avant la phase commerciale, conduire à titre indicatif cinq à dix entretiens lecteurs et trois entretiens éditeurs. Vérifier l'intérêt pour les formats, moyens de paiement, langues, prix envisagés et conditions de distribution. Documenter les objections et décider de poursuivre, réduire ou réorienter le périmètre.

Le pilote doit suivre le taux de réussite par parcours, le nombre de tickets évités ou résolus, la satisfaction déclarée et les abandons. Les cibles commerciales seront fixées après une première mesure. Un clic, un nombre de conversations ou un nombre d'agents ne constitue pas à lui seul une preuve de valeur.

## Réutilisation des acquis

Les principes d'approbation, RAG et API des projets antérieurs peuvent être réutilisés après revue. Le code propriétaire d'un employeur ou client ne doit pas être importé sans autorisation. Le nouveau dépôt doit posséder ses propres données fictives, migrations, tests et instructions reproductibles.

# 3 Périmètre et frontières du produit

## Versions prévues

| Domaine | MVP P0 | Pilote P1 | Évolution P2 |
|---|---|---|---|
| Catalogue | 3 univers, PDF et texte, extraits | Audio, import éditeur contrôlé | Vidéo, recommandations personnalisées |
| Commerce | Gratuit, achat unitaire, abonnement manuel en test | Prestataire réel validé, remboursements encadrés | Récurrence, cadeaux, offres organisations |
| Assistant | Coordinateur et 3 spécialistes, 3 MCP | Assistance dédiée, mesures sur utilisateurs | Nouveaux domaines justifiés par évaluations |
| Administration | Catalogue, offres, accès, tickets, approbations | Espace éditeur et suivi qualité | Revenus éditeurs et exports avancés |
| Déploiement | En ligne, persistance, reprise testée | Sauvegardes et supervision opérationnelles | Montée en charge selon mesures |

## Hors périmètre initial

Le MVP n’inclut pas la livraison papier, les reversements automatiques aux éditeurs, une comptabilité complète, l’hébergement de modèles lourds, une application mobile native, une place de marché ouverte sans modération ou une gestion de DRM propriétaire. Il ne fournit pas de conseil juridique personnalisé ni de décisions financières autonomes.

Les fonctions affichées doivent correspondre à une implémentation réelle. Les paiements, contenus et offres de démonstration portent un libellé explicite. Un connecteur non activé ne peut apparaître comme connecté. Les modules futurs restent absents des parcours transactionnels.

## Hypothèses à confirmer

Le lancement commercial dispose d’une entité contractante, de contenus autorisés et d’un moyen de paiement compatible avec son pays et ses utilisateurs. Aucune disponibilité commerciale de Stripe, de Mobile Money ou d’un autre prestataire n’est présumée. Les zones géographiques, taxes, obligations de facturation et règles de remboursement doivent être cadrées avant d’encaisser.

Le MVP utilise un catalogue de 12 à 20 publications de démonstration, deux éditeurs fictifs et au moins six offres. Deux clients et deux éditeurs distincts permettent de vérifier les frontières d’accès. L’abonnement est individuel ; le partage familial et les sièges d’organisation ne sont pas implicitement permis.

## Extension du périmètre

Une extension doit définir son problème utilisateur, ses données, ses droits, ses risques et son critère de réussite. Elle nécessite une migration compatible et des tests de non-régression. L’ajout d’un agent n’est accepté que si la spécialisation, le contexte ou les outils justifient sa séparation.

# 4 Utilisateurs et permissions

## Rôles

| Rôle | Lectures autorisées | Écritures autorisées |
|---|---|---|
| Visiteur | Catalogue public, extraits autorisés, offres | Créer un compte ; demander un conseil public |
| Lecteur | Son profil, commandes, abonnements, bibliothèque | Préparer un achat, confirmer ses actions, ouvrir un ticket |
| Éditeur | Ses œuvres, contrats de diffusion, indicateurs agrégés | Déposer et corriger ses contenus en attente de validation |
| Support | Dossiers nécessaires à un ticket attribué | Répondre, proposer une résolution, demander une approbation |
| Responsable | Dossiers et demandes de son périmètre | Approuver les exceptions autorisées et remboursements |
| Administrateur | Configuration et opérations autorisées | Publier, gérer les rôles, suspendre et auditer |
| Compte de service | Seulement les ressources de sa mission | Seulement les outils et opérations déclarés |

## Exigences

- IAM01 P0 : vérifier l'identité et les permissions sur chaque requête REST et chaque outil MCP, y compris les exports et fichiers.
- IAM02 P0 : dériver user_id et publisher_id du contexte authentifié ; un paramètre envoyé par le navigateur ou le modèle ne suffit jamais à changer de périmètre.
- IAM03 P0 : contrôler les objets référencés par identifiant. Deviner un UUID ne permet ni lecture ni écriture.
- IAM04 P0 : les listes de catalogue public peuvent agréger plusieurs éditeurs ; les brouillons, contrats, revenus et tickets restent filtrés.
- IAM05 P1 : les interventions du support sur un compte lecteur exigent un ticket, un motif et un audit ; pas d'usurpation silencieuse.
- IAM06 P1 : imposer une authentification renforcée aux rôles privilégiés avant exposition de données ou paiements réels.

## Matrice des actions sensibles

Le lecteur confirme ses propres achats ou changements. Un responsable valide une exception commerciale, un remboursement manuel ou un rétablissement exceptionnel d'accès. Le demandeur d'une exception à fort impact ne peut approuver lui-même sa demande. Le backend applique cette séparation, même si le modèle affirme qu'une autorisation existe.

La révocation d'un rôle ou d'une session doit empêcher une mutation future, y compris la reprise d'un agent ou une approbation préparée précédemment. Chaque tâche différée revalide les permissions actuelles avant une écriture.

### Preuve de recette

Créer deux éditeurs et deux lecteurs. Tenter une lecture et modification croisées via API, MCP et URL de fichier. Toutes les opérations interdites doivent échouer sans divulguer le contenu. Les agrégats publics restent visibles selon la politique de publication.

# 5 Catalogue et publication des contenus

## Modèle éditorial

Une publication représente une œuvre ou une série ; une édition représente un numéro ou une version vendable. Un fichier est un support associé à cette édition. Un même titre peut avoir un extrait public et un fichier intégral privé. Le catalogue distingue titre, auteur, éditeur, langue, univers, format, résumé, tags, date de publication et disponibilité.

La disponibilité de diffusion comprend un territoire, une période et une autorisation d'usage du texte dans la recherche IA. L'indexation intégrale, la génération d'extraits et la lecture publique sont trois permissions distinctes.

## Exigences

- CAT01 P0 : filtrer par univers, langue, format et prix ; pagination bornée, tri stable et résultat vide compréhensible.
- CAT02 P0 : afficher les éléments inclus dans l'offre, ses restrictions et le statut de disponibilité avant achat.
- CAT03 P0 : proposer un extrait public explicitement autorisé sans exposer le fichier complet.
- CAT04 P0 : appliquer le cycle draft → review → published → suspended ou archived ; seul un rôle autorisé publie.
- CAT05 P0 : valider taille, extension, type réel et cohérence du fichier ; stocker en quarantaine avant traitement.
- CAT06 P1 : autoriser le dépôt par éditeur, avec validation et preuve des droits attachées à chaque édition.
- CAT07 P1 : synchroniser retrait, expiration de droits et désindexation ; invalider les caches concernés.
- CAT08 P2 : ajouter audio, vidéo, séries, collections et recommandations personnalisées sans modifier les commandes historiques.

## Publication et retrait

L'import produit un identifiant de traitement consultable. L'ingestion extrait le texte, vérifie la lisibilité et construit l'index. Un fichier scanné sans texte doit être signalé ; l'OCR est une option ultérieure et non une réussite implicite. Une nouvelle version conserve l'historique et ne remplace pas silencieusement le contenu d'un achat passé.

Un retrait bloque les nouvelles ventes. L'effet sur les accès déjà acquis dépend du contrat et doit être décidé explicitement, enregistré et communiqué. Une demande de retrait urgent coupe les accès concernés et déclenche une revue humaine selon la politique validée.

## Recette

Un fichier interdit est rejeté ; un brouillon n'est pas public ; un extrait ne donne pas accès au fichier complet ; une édition expirée disparaît des offres actives. Les anciens reçus continuent de refléter le titre, la version et le prix achetés.

# 6 Offres commerciales et droits de lecture

## Structure des offres

| Offre | Contenu inclus | Droit accordé |
|---|---|---|
| Gratuit | Sélection publiée et extraits | Consultation selon la politique publique |
| Achat unitaire | Une édition déterminée | Accès selon la durée et la licence annoncées |
| Abonnement thématique | Sélection définie par un périmètre versionné | Accès pendant une période déterminée |
| Cadeau P2 | Édition ou durée d'abonnement | Code d'activation personnel, expirant selon les conditions |
| Organisation P2 | Catalogue et nombre de sièges contractuels | Accès nominatif, attribution et révocation contrôlées |

## Règles obligatoires

- OFF01 P0 : versionner prix, monnaie, durée, contenu inclus et conditions. Une offre achetée référence un instantané immuable.
- OFF02 P0 : calculer le total côté serveur. Aucun prix, taxe ou remise fourni par le client ou le LLM n'est considéré comme autoritaire.
- OFF03 P0 : distinguer contenu numérique non contingenté et quota d'une offre. Un article numérique peut avoir plusieurs lecteurs autorisés.
- OFF04 P0 : signaler avant achat si le lecteur possède déjà le contenu ou un accès équivalent ; empêcher le doublon strict et expliquer les chevauchements.
- OFF05 P0 : donner une date de début et de fin explicites ; les dates sont stockées en UTC et affichées dans le fuseau choisi.
- OFF06 P1 : valider les règles de taxes, facturation, territoire et devise avec le prestataire et le responsable commercial.

## Droits techniques

Un entitlement est le droit technique de lire une édition ou un ensemble défini. Il référence sa source : achat, abonnement, cadeau ou attribution administrative. Il possède une période de validité et un statut. Le contrôle s'effectue à chaque demande de contenu protégé, et non uniquement lors de la connexion.

Pour le MVP, l'abonnement inclut une collection dont les ajouts futurs sont accessibles pendant la période active. Une suppression ne doit pas changer arbitrairement la promesse commerciale ; une règle explicite de retrait est nécessaire. Le moteur doit conserver le périmètre de l'offre et les événements qui l'ont fait évoluer.

## Monnaies et présentation

Le catalogue de démonstration utilise MGA. Stocker les montants en entier avec une unité monétaire documentée et un code de devise ; ne pas supposer que toutes les devises utilisent deux décimales. Le pilote vérifie les unités attendues par son prestataire. Une conversion indicative n'est jamais un montant de paiement confirmé.

# 7 Abonnements et cycle de vie

## États métier

| État | Signification | Accès |
|---|---|---|
| pending_payment | Commande créée, paiement non confirmé | Aucun nouvel accès |
| active | Paiement ou attribution validée | Accès selon le périmètre et les dates |
| cancel_at_period_end | Renouvellement désactivé ou fin demandée | Maintenu jusqu'à la fin prévue |
| past_due | Renouvellement réel en échec, si activé en P1 | Selon la période de grâce contractuelle |
| expired | Période terminée | Nouvel accès refusé |
| suspended | Suspension motivée par un rôle autorisé | Selon le périmètre de suspension |

## Exigences

- SUB01 P0 : afficher l'état, les dates, les contenus inclus et le mode de renouvellement avant et après souscription.
- SUB02 P0 : créer un abonnement actif uniquement à partir d'une preuve de paiement validée ou d'une attribution administrative auditée.
- SUB03 P0 : exécuter la fin d'accès par tâche planifiée, tout en contrôlant les dates à chaque lecture pour ne pas dépendre uniquement du planificateur.
- SUB04 P0 : prévoir un renouvellement manuel explicite ; aucune promesse de prélèvement automatique au MVP.
- SUB05 P0 : une résiliation confirmée ne supprime pas l'historique. La fin à échéance est le comportement par défaut proposé.
- SUB06 P1 : proposer un changement de formule avec simulation serveur et conditions explicites ; pas de prorata calculé par le modèle.
- SUB07 P1 : activer une récurrence uniquement si le prestataire gère le mandat, les échecs et les notifications nécessaires.

## Confirmation des changements

Le serveur prépare un devis d'action contenant ancienne offre, nouvelle offre, différence de prix, dates d'effet, version des conditions et date d'expiration. Le lecteur confirme cet objet précis. Une modification de prix, d'éligibilité ou de contrat invalide la proposition et exige une nouvelle confirmation.

Le MVP peut limiter les changements à la prochaine échéance, ce qui réduit les cas de prorata et de double facturation. Les transitions autorisées sont codées et testées ; une requête répétée ne crée ni second abonnement ni seconde notification.

### Recette

Vérifier achat en attente, activation, expiration, fin à échéance, résiliation répétée et changement devenu obsolète. Deux demandes de renouvellement simultanées ne doivent pas créer deux périodes ou paiements involontaires. Toute exception de support laisse une justification et une trace d'audit.

# 8 Commandes et intégration du paiement

### Parcours de paiement

Le backend crée une commande à partir d'un instantané de l'offre. Il réserve un quota si nécessaire, puis demande une session de paiement au connecteur. Le navigateur reçoit une URL de paiement ou des instructions du prestataire. Le retour de navigation n'est jamais une preuve suffisante de paiement ; seule une notification vérifiée ou une réconciliation serveur peut confirmer la commande.

### Exigences

- PAY01 P0 : implémenter une interface PaymentProvider avec create_checkout, verify_event, get_payment_status et, en P1, request_refund.
- PAY02 P0 : fournir un adaptateur de test explicite ; aucun numéro de carte ni secret de paiement dans les données de démonstration.
- PAY03 P1 : choisir un prestataire après vérification de l'éligibilité du marchand, pays, devises, frais, récurrence, remboursements et environnement de test.
- PAY04 P1 : valider l'authenticité de chaque notification selon le protocole du prestataire, sur le corps original si requis ; vérifier montant, monnaie, référence et état.
- PAY05 P0 : dédupliquer les événements reçus et supporter leur ordre non garanti. Conserver une boîte de réception persistante avant traitement.
- PAY06 P1 : mettre en place une réconciliation périodique pour les paiements dont le résultat est inconnu ou dont la notification manque.
- PAY07 P1 : journaliser les remboursements et désaccords de paiement ; revalider les accès selon la règle contractuelle.

### États et transactions

Une commande suit created, pending_payment, paid, fulfilled, cancelled ou payment_exception. Un paiement suit son propre état : initiated, pending, succeeded, failed, refund_pending, refunded. Les états ne sont pas confondus : un remboursement demandé n'est pas encore un remboursement réussi.

L'activation de l'abonnement, l'attribution des droits et l'événement à envoyer sont enregistrés dans une transaction locale. Une outbox conserve l'événement pour traitement asynchrone après commit. Les appels au prestataire ne sont pas placés dans une transaction SQL longue.

### Cas limites

Si une création de paiement expire sans réponse, réinterroger le prestataire avec la même référence avant de recréer une session. Si le paiement arrive après expiration d'une réservation, tenter une réattribution atomique ; sinon créer un dossier d'exception et appliquer une compensation définie. Ne jamais annoncer automatiquement une disponibilité perdue.

Le document de recette doit couvrir les notifications invalides, dupliquées, retardées et contradictoires. La documentation du prestataire retenu prime pour son protocole exact ; la référence Stripe en annexe illustre les webhooks sans constituer un choix commercial.

# 9 Concurrence et prévention des doublons

### Attribution d’une quantité limitée

La première transaction qui réserve avec succès obtient la place. L’ordre des clics dans les navigateurs n’est pas garanti. Une publication numérique sans quota n’utilise pas de stock ; le mécanisme s’applique aux offres promotionnelles limitées, licences à places et futurs articles physiques.

CON01 P0 : décrémenter le quota par une opération atomique conditionnelle et créer la réservation dans la même transaction. Exemple de principe PostgreSQL :

```
UPDATE offers SET remaining = remaining - 1
WHERE id = :offer_id AND remaining > 0
RETURNING id;
```

Une absence de résultat produit une réponse métier OFFER_SOLD_OUT. Un rollback restaure aussi le quota. Ajouter une contrainte empêchant remaining de devenir négatif. Les transactions conflictuelles doivent être gérées selon le niveau d’isolation choisi [R3].

### Réservation et expiration

CON02 P0 : enregistrer reserved, consumed, released ou expired, une échéance calculée côté serveur et la commande associée. Une durée initiale de dix minutes est une hypothèse à tester. Le passage de reserved à consumed ou expired doit être atomique et exclusif. La restitution du quota n’est autorisée qu’une fois.

CON03 P0 : un worker d’expiration et un webhook de paiement concurrents ne doivent pas pouvoir chacun finaliser un état incompatible. Utiliser verrouillage de ligne ou comparaison atomique d’état ; toute réattribution après expiration constitue une nouvelle opération explicite.

### Idempotence

CON04 P0 : l’API exige Idempotency-Key pour les créations de commande et confirmations. La clé est associée à l’utilisateur, l’opération et une empreinte du corps. Même clé et même corps renvoient le résultat initial ; même clé et corps différent renvoient 409. Conserver initialement ces enregistrements sept jours, sous réserve des exigences du prestataire.

CON05 P0 : contraintes uniques pour référence de paiement, événement fournisseur et exécution d’action. Les workers peuvent recevoir un travail plusieurs fois ; les effets métier doivent rester idempotents. Ne pas revendiquer une exécution exactement une fois entre systèmes distribués.

### Test obligatoire

Lancer 100 demandes distinctes simultanées pour un quota de un sur PostgreSQL réel : une seule réservation réussit, 99 reçoivent un refus cohérent, quota final zéro. Répéter avec expiration concurrente au paiement et vérifier l’absence de double activation ou double restitution.

# 10 Interfaces et expérience utilisateur

### Écrans attendus

| Espace | Écrans du MVP | États à prévoir |
|---|---|---|
| Public | Accueil, catalogue, publication, offre, connexion | Chargement, vide, erreur, indisponible |

| Espace | Écrans du MVP | États à prévoir |
|---|---|---|
| Lecteur | Bibliothèque, détail abonnement, commandes, KIA, tickets | Accès actif, expiré, paiement en attente |
| Administration | Contenus, offres, droits, tickets, approbations, traces | Brouillon, à revoir, suspendu, échec |
| Éditeur P1 | Dépôts, versions, offres proposées, statistiques | Rejet motivé, validation, retrait |

### Exigences ergonomiques

- UX01 P0 : interface responsive utilisable à partir de 360 px ; navigation clavier, focus visible, labels de formulaire et messages d'erreur compréhensibles.
- UX02 P0 : afficher prix, devise, durée et renouvellement au même endroit avant confirmation ; pas d'option payante présélectionnée silencieusement.
- UX03 P0 : dans KIA, distinguer réponse informative, action préparée, attente de validation, action réalisée et échec.
- UX04 P0 : proposer des cartes comparatives d'offres et des sources ouvrables. Le lecteur peut terminer les mêmes actions par les formulaires classiques.
- UX05 P0 : après reconnexion, retrouver sa conversation et la tâche en cours. Une coupure de flux ne signifie pas un échec métier.
- UX06 P1 : évaluer la navigation en réseau mobile lent ; chargement différé des couvertures, pagination et consultation d'extraits légers.

### Parcours conversationnel

Une demande anonyme peut consulter le catalogue public. Une demande personnelle déclenche une invitation à s'authentifier, sans exposer de dossier. Les confirmations présentent les conséquences exactes et un bouton explicite. Un refus utilisateur annule la proposition, sans pression ni nouvelle tentative automatique.

Le lecteur voit des étapes courtes telles que « comparaison des offres » ou « vérification de votre accès ». Le tableau de diagnostic réservé aux développeurs montre les agents, outils, durées et erreurs. Il ne contient pas de chaîne de pensée privée du modèle ; seulement des décisions résumées, entrées minimisées et résultats vérifiables.

### Langues et accessibilité

Le français est obligatoire au MVP. L'interface doit externaliser ses chaînes pour ajouter le malgache et l'anglais. Les réponses en malgache ne sont activées qu'après évaluation par des locuteurs compétents. Le lecteur conserve la langue d'origine d'un document ; une traduction générée est identifiée comme telle et respecte les droits associés.

La cible de conception est WCAG 2.2 AA pour les parcours essentiels. La recette vérifie concrètement contrastes, clavier, intitulés, zoom et retours d'erreur ; aucune certification d'accessibilité n'est présumée.

# 11 Coordination des agents

## Architecture fonctionnelle

Le backend joue le rôle d'hôte MCP et exécute un coordinateur LangGraph. Le coordinateur choisit une réponse directe, une clarification ou une délégation. Chaque spécialiste dispose de son contexte, de ses outils autorisés et d'un schéma de sortie. Le coordinateur exploite leurs résultats pour formuler une réponse ou proposer une action.

Un routeur qui appelle un seul prompt spécialisé ne suffit pas à démontrer la coopération. Au moins un parcours de recette doit présenter une dépendance réelle : le résultat d'un spécialiste modifie la mission ou la conclusion d'un autre.

## Exigences d'orchestration

- AG01 P0 : sélectionner les spécialistes selon la demande ; ne pas déclencher tous les agents pour une simple question de prix.
- AG02 P0 : gérer les branches clarification, délégation, consolidation, préparation d'action, attente d'approbation, exécution et escalade.
- AG03 P0 : exécuter en parallèle uniquement les recherches indépendantes. Les mutations dépendantes restent séquentielles.
- AG04 P0 : persister l'état à chaque étape utile et avant toute attente. Le checkpoint permet la reprise mais ne remplace pas l'idempotence métier [R2].
- AG05 P0 : revalider les autorisations, versions et conditions lors de la reprise ; refuser une proposition devenue obsolète.
- AG06 P0 : borner la durée, le nombre de délégations, appels d'outils et tokens. Arrêter proprement avec un résultat partiel ou un transfert humain.
- AG07 P0 : distinguer résultat fourni par un outil et hypothèse du modèle. Ne jamais annoncer un achat, remboursement ou accès sans preuve d'exécution.

## État persistant

AgentRun contient run_id, conversation_id, actor_id, scopes, demande, statut, versions de prompts et modèles, budget consommé et références aux résultats. Les statuts sont queued, running, waiting_user, waiting_approval, completed, failed ou cancelled. Un numéro de séquence ordonne les événements affichés.

Chaque conversation possède une file ordonnée ou un contrôle de version afin que deux messages simultanés ne modifient pas le même état de façon incohérente. Les effets déjà exécutés ne sont pas annulés par un simple arrêt de conversation ; une compensation distincte est nécessaire.

## Paramètres initiaux proposés

Limiter un run à quatre délégations, douze appels d'outils et 120 secondes de travail actif, puis calibrer sur les tests. L'attente humaine n'entre pas dans cette durée. Le plafond de tokens et de coût doit être configuré après choix des modèles et mesuré sur le corpus d'évaluation.

# 12 Responsabilités des spécialistes

## Contrats des agents

| Agent | Entrées utiles | Sortie attendue |
|---|---|---|
| Conseil éditorial | Besoin, langue, format, budget déclaré | Candidats justifiés, critères et questions restantes |
| Offres et abonnements | Candidats, accès existants, offres serveur | Comparaison, doublons et proposition métier référencée |
| Conditions et droits | Offre, contrat applicable, territoire pertinent | Règles sourcées, restrictions et incertitudes |
| Assistance P1 | Erreur, appareil, droits et ticket | Diagnostic, étapes sûres ou escalade |

## Frontières

Le conseiller ne crée pas de paiement. Le spécialiste offres ne calcule pas librement les taxes ni les remises : il appelle une fonction déterministe. Le spécialiste conditions cite la version applicable du document ; il ne rend pas une décision juridique contraignante. L’assistance ne désactive pas les contrôles d’accès pour contourner une panne.

Le coordinateur ne reçoit pas automatiquement les contrats complets, adresses, historiques de paiement et contenus intégraux. Il obtient les éléments nécessaires à la synthèse. Le contexte d’un agent n’est pas une permission supplémentaire.

## Schéma commun de résultat

Chaque AgentResult comprend status (ok, needs_input, blocked, failed), summary, evidence_refs, proposed_actions, missing_information, warnings et trace_id. Une assertion factuelle importante doit référencer une source, un résultat d’outil ou être signalée comme non vérifiée. La confiance auto-déclarée par le LLM ne suffit pas à autoriser une écriture.

Une proposition d’action comprend type, resource_id, paramètres normalisés, version de ressource, conséquences, approbation requise et date d’expiration. Le backend la valide contre un schéma fermé ; les propriétés non reconnues sont rejetées.

## Scénario de référence

Un lecteur demande une offre business et agriculture sans repayer ses accès actuels. Le conseiller identifie les candidats ; le spécialiste abonnements élimine les achats redondants ; le spécialiste conditions vérifie le périmètre de diffusion et les modalités du changement. Le coordinateur propose les alternatives compatibles, puis prépare une opération si le lecteur en choisit une.

Si le catalogue ne couvre pas l’agriculture, le système le dit. Si deux documents se contredisent, il montre le conflit et demande une revue. Si un outil échoue, il ne remplace pas une donnée personnelle manquante par une supposition.

## Critère d’intégration

Un test enregistre au moins deux spécialistes, leurs résultats structurés, la dépendance utilisée et l’action finale ou son refus motivé. Les traces techniques sont accessibles uniquement aux rôles autorisés.

# 13 Catalogue des outils MCP

## Organisation des serveurs

Trois serveurs logiques fournissent des capacités distinctes. Ils peuvent partager le dépôt et les services métier, mais doivent avoir des routes, contrats et autorisations identifiables. Le déploiement conserve de vrais échanges MCP testables ; renommer une fonction Python « MCP » n'est pas suffisant [R1].

| Serveur | Outil | Effet et contrôle principal |
|---|---|---|
| Catalogue | search_publications | Lecture filtrée, pagination et critères bornés |
| Catalogue | get_publication | Métadonnées publiques ou autorisées |
| Catalogue | get_authorized_excerpt | Extrait selon droits et limite de longueur |
| Catalogue | compare_offers | Comparaison déterministe des offres actuelles |
| Abonnements | get_my_subscriptions | Lecture liée à l'identité serveur |
| Abonnements | check_entitlement | Vérifier un accès sans révéler d'autres dossiers |
| Abonnements | prepare_purchase | Proposition de commande, sans paiement |
| Abonnements | prepare_plan_change | Simulation serveur et proposition versionnée |
| Abonnements | prepare_cancellation | Proposition de fin selon conditions |
| Support | search_terms | Recherche documentaire filtrée et datée |
| Support | create_support_case | Ticket pour l'acteur autorisé, idempotent |
| Support | get_my_case | Lecture de son ticket et de son état |

## Confirmation et exécution

Le modèle n'accède pas à un outil universel execute_sql, arbitrary_http ou modify_permissions. Les outils de préparation ne débitent pas de paiement. Une commande REST de confirmation exécute la proposition via les services métier communs, après contrôle de l'utilisateur. Si un exécuteur MCP est ajouté, il exige une approbation serveur signée et spécifique à l'action ; un argument approved=true ne suffit jamais.

## Contrats et erreurs

Chaque outil possède nom stable, version, description, inputSchema fermé, résultat structuré, portée requise, délai, caractère mutatif et politique de répétition. Le résultat distingue succès, refus métier, erreur transitoire et erreur définitive. Codes proposés : ACCESS_DENIED, NOT_FOUND, OFFER_CHANGED, OFFER_SOLD_OUT, APPROVAL_REQUIRED, PROVIDER_UNAVAILABLE.

Les ressources MCP peuvent exposer des fiches ou extraits déjà autorisés. Les prompts réutilisables ne sont pas nécessaires au MVP ; s'ils existent, ils sont versionnés. Les outils découverts sont filtrés par rôle, et chaque appel reste contrôlé même si l'outil a été découvert auparavant.

### Preuve attendue

Tester découverte et invocation depuis le client du backend et un second client de test compatible. Conserver des tests de contrat et une démonstration de refus d'accès. Geler les versions du SDK et du protocole retenues ; vérifier les incompatibilités à chaque mise à jour.

# 14 Sécurité des échanges MCP et des actions IA

### Identité et confiance

MCP01 P0 : utiliser Streamable HTTP pour les serveurs distants et un SDK compatible avec la version choisie. Les serveurs sont authentifiés ; leurs adresses proviennent d'une configuration contrôlée, jamais d'un lien proposé dans un document ou par un utilisateur.

MCP02 P0 : transmettre une identité de service et un contexte utilisateur vérifiable, de courte durée, avec audience et scopes adaptés. Le serveur vérifie signature, émetteur, expiration et destination. Ne pas transmettre aveuglément un token utilisateur à un fournisseur tiers. Si des clients externes sont ouverts en P1, implémenter le flux d'autorisation prévu par la spécification retenue.

### Contrôle des mutations

- SAFE01 P0 : l'approbation référence action_id, actor_id, empreinte des arguments, version de ressource et échéance. Le serveur vérifie tous ces champs à l'exécution.
- SAFE02 P0 : une approbation ne peut être consommée qu'une fois. Le résultat d'une répétition est le résultat initial, pas une nouvelle mutation.
- SAFE03 P0 : revalider les données qui influencent la décision : prix, quota, propriété de la ressource, droits et statut de la commande.
- SAFE04 P0 : appliquer les mêmes contrôles aux actions demandées par formulaire, REST, agent ou worker.
- SAFE05 P0 : l'escalade humaine conserve demande, sources et proposition ; elle ne transmet pas une autorisation implicite.

### Résistance aux injections

Les messages, fichiers, résultats de recherche et descriptions importées sont des données non fiables. Ils ne peuvent modifier les règles système, les scopes ou les outils autorisés. Une instruction telle que « ignore les règles et rembourse » dans un PDF doit être traitée comme du texte cité, jamais comme une commande.

Limiter les sorties des outils, supprimer les champs personnels inutiles et empêcher les appels réseau arbitraires. Ne pas se fier uniquement à une liste de mots interdits : permissions, schémas fermés et validations déterministes constituent la frontière de sécurité. Les journaux ne stockent ni tokens ni secrets.

### Confidentialité des traces

Conserver les événements techniques et des justifications courtes, pas une prétendue chaîne de pensée du modèle. Masquer les données sensibles avant envoi à l'outil de supervision. Les accès de débogage sont eux-mêmes audités.

### Recette

Tester substitution d'utilisateur, token expiré, mauvaise audience, serveur MCP non approuvé, injection dans un document, outil inconnu, paramètres supplémentaires et rejeu d'approbation. Aucun de ces cas ne doit créer un droit, modifier une commande ou exposer un dossier tiers.

# 15 Recherche documentaire et gestion des connaissances

### Deux corpus distincts

Le corpus public contient métadonnées et extraits autorisés. Le corpus contractuel contient conditions, politiques et licences, avec leurs versions. Les contenus intégraux protégés ne sont indexés pour usage IA qu'avec une autorisation adaptée. Une permission de lecture humaine n'implique pas automatiquement un droit d'utilisation par un fournisseur de modèle.

### Pipeline

RAG01 P0 : importer, vérifier, extraire, découper, indexer et enregistrer l'état de traitement. Chaque chunk conserve document_id, version, éditeur, langue, date d'effet, page ou section, visibilité et empreinte. Les erreurs d'extraction ne produisent pas un document marqué prêt.

RAG02 P0 : appliquer les filtres d'accès avant restitution au modèle. La recherche lexicale et vectorielle peut être combinée ; le reranking est activé après mesure de son apport. Conserver un jeu de référence pour la pertinence et la qualité des citations.

RAG03 P0 : pour une question contractuelle, sélectionner la version applicable à la commande ou au contrat. Présenter un conflit ou une absence de preuve au lieu de composer une règle inexistante.

### Sources et limites de réponse

Les citations doivent pointer vers un document et un passage existants, consultables par l'utilisateur autorisé. Une citation non ouvrable pour cet utilisateur est remplacée par une explication et une référence accessible, sans fuite de texte privé. Le serveur construit les références ; le modèle ne doit pas inventer d'URL.

Les réponses refusent la restitution massive d'une œuvre protégée. Les limites d'extraits sont paramétrées selon les droits de diffusion. Un changement de droits retire le contenu de la recherche et invalide les caches et réponses préconstruites concernés.

### Mise à jour et suppression

Un réindexage est versionné, relançable et idempotent. L'ancienne version reste active jusqu'à validation de la nouvelle, sauf retrait urgent. Les tombstones de suppression empêchent de réintroduire un document retiré lors d'une reprise de tâche. L'invalidation doit couvrir SQL, index vectoriel, stockage et cache selon la politique de conservation.

### Modèles et mémoire

Les prompts, modèles de génération, embeddings et paramètres sont versionnés. Un changement d'embeddings impose un index compatible ; ne pas mélanger des vecteurs de dimensions ou d'espaces différents. La mémoire conversationnelle conserve des faits explicites et utiles, avec durée et suppression prévues. Les résumés ne deviennent pas une source autoritaire pour prix, paiement ou droits d'accès.

# 16 Modèle de données et invariants

## Entités principales

| Groupe | Entités | Relations essentielles |
|---|---|---|
| Identité | User, Session, Publisher, Membership | Rôle lié à un utilisateur et à un périmètre |
| Catalogue | Publication, Edition, Asset, License | Édition et fichiers liés à un éditeur autorisé |
| Commerce | Offer, OfferVersion, OfferItem, Order, OrderLine | Lignes liées à un instantané de l'offre |
| Accès | Subscription, Entitlement | Droits liés à une source et à une période |
| Paiement | Payment, ProviderEvent, Refund | Références prestataire uniques |
| Concurrence | Reservation, IdempotencyRecord | État atomique et empreinte de requête |
| IA | Conversation, Message, AgentRun, AgentStep | Événements ordonnés et états persistants |
| Gouvernance | ActionProposal, Approval, AuditEvent | Arguments et versions approuvés, acteur et résultat |
| Documents | KnowledgeDocument, Chunk, IngestionJob | Source, version, visibilité et index |
| Exploitation | SupportCase, OutboxEvent, Job | Reprise, tentatives et corrélation |

## Contraintes

DATA01 P0 : clés étrangères, unicité des références externes, contraintes de statut et de non-négativité. Utiliser un mécanisme de version pour les ressources modifiables. Les dates portent un fuseau ; les montants ne sont pas des flottants binaires.

DATA02 P0 : séparer commande, paiement, abonnement et droit d'accès. Un paiement réussi peut nécessiter une intervention si l'exécution métier échoue ; il ne doit pas être perdu ni représenté comme remboursé sans preuve.

DATA03 P0 : filtrer publisher_id sur les ressources éditoriales et user_id sur les dossiers personnels. Un lecteur peut acheter auprès de plusieurs éditeurs ; son compte n'appartient donc pas à un seul tenant éditeur. Les relations de visibilité sont explicites.

DATA04 P1 : ajouter une défense PostgreSQL RLS si retenue, avec rôle applicatif non superutilisateur et tests réels. Les filtres applicatifs restent obligatoires ; ne pas annoncer RLS avant son implémentation et sa recette.

## Historique et migrations

Conserver des instantanés de prix, intitulés, conditions et périmètres vendus. Les événements d'audit sont ajoutés sans modification ordinaire. Les suppressions de profil doivent respecter les durées de conservation décidées pour les preuves transactionnelles ; pseudonymiser lorsque la suppression physique n'est pas appropriée.

Toutes les évolutions passent par Alembic, avec migration testée sur copie de données. Utiliser une approche compatible avec l'ancienne et la nouvelle version pendant un déploiement. Les données de démonstration sont idempotentes, clairement identifiées et interdites automatiquement dans l'environnement commercial.

# 17 Contrats des API REST

### Endpoints proposés

| Méthode et route | Fonction | Contrôle |
|---|---|---|
| GET /v1/publications | Catalogue public filtré | Pagination, publication et droits |
| GET /v1/offers/{id} | Offre courante | Visibilité et validité |
| GET /v1/me/library | Bibliothèque du lecteur | Session et droits personnels |
| POST /v1/orders | Préparer une commande | Idempotency-Key, prix serveur |
| POST /v1/orders/{id}/checkout | Créer une session de paiement | Propriété, état et connecteur |
| POST /v1/webhooks/payments/{provider} | Recevoir un événement | Vérification fournisseur, déduplication |
| POST /v1/conversations/{id}/runs | Lancer un traitement IA | Propriété, quotas et budget |
| GET /v1/runs/{id} | État et résultat | Propriété ou rôle autorisé |
| GET /v1/runs/{id}/events | Flux de progression | Session, reprise par séquence |
| POST /v1/proposals/{id}/confirm | Confirmer une action | Identité, version, échéance et idempotence |
| POST /v1/proposals/{id}/reject | Refuser une action | Propriété ou rôle approbateur |
| GET /v1/assets/{id}/access | Demander un accès fichier | Entitlement puis URL limitée |

### Réponses et erreurs

API01 P0 : documenter les contrats OpenAPI et générer les types TypeScript. Réponses d'erreur : code, message public, request_id et détails de validation non sensibles. Codes HTTP cohérents : 401 non authentifié, 403 interdit, 404 absent ou masqué, 409 conflit, 422 invalide, 429 quota et 503 dépendance indisponible.

API02 P0 : une tâche longue renvoie 202 avec run_id et URL d'état. Le navigateur suit les événements ou interroge le statut ; il n'attend pas toute l'exécution dans une requête bloquante. Un événement completed signifie que le résultat est persisté.

API03 P0 : borner pagination, taille des corps, fichiers, messages, filtres et durées. Les écritures sensibles utilisent un DTO fermé. Aucune route de mise à jour générique ne permet de modifier rôle, prix, paiement ou propriétaire.

### Sessions et domaines

Le frontend appelle directement l'API Render en HTTPS. Préférer à terme app.domaine et api.domaine. Utiliser des cookies HttpOnly, Secure et une protection CSRF adaptée ; vérifier les contraintes intersites si les domaines

Vercel et Render par défaut sont conservés. Ne pas stocker de token durable dans localStorage par défaut. CORS autorise les origines prévues mais ne constitue jamais un mécanisme d'authentification.

# 18 Sécurité applicative et données personnelles

### Exigences prioritaires

- SEC01 P0 : hacher les mots de passe avec une fonction dédiée moderne ; limiter les tentatives, prévoir réinitialisation à usage unique et révocation des sessions.
- SEC02 P0 : tokens et sessions expirants, secrets distincts par environnement, absence de secrets dans le bundle React ou le dépôt.
- SEC03 P0 : vérifier les permissions sur chaque objet, fichier, recherche et export ; tester les accès croisés systématiquement.
- SEC04 P0 : requêtes SQL paramétrées, validation serveur, échappement des contenus et rendu Markdown sans HTML dangereux.
- SEC05 P0 : protéger les imports contre fichiers surdimensionnés, chemins malveillants et types incohérents ; analyse antivirus avant publication réelle en P1.
- SEC06 P0 : refuser l'accès réseau arbitraire depuis les outils et parseurs ; allowlist de destinations, contrôle des redirections et adresses internes si téléchargement distant ajouté.
- SEC07 P0 : limiter les appels IA, réservations et téléchargements par compte et contexte ; quotas distribués pour plusieurs instances.
- SEC08 P1 : MFA des comptes privilégiés, revue des dépendances et secrets, procédure d'incident et tests de restauration.

### Distribution des contenus

Les fichiers intégraux restent privés. Une URL signée expire rapidement et n'est créée qu'après contrôle d'accès. Elle ne garantit pas qu'un lecteur ne copiera jamais un fichier déjà téléchargé ; la promesse produit doit refléter cette limite. Pour un retrait immédiat, un proxy authentifié peut être nécessaire selon les exigences et coûts.

Les caches de réponses personnelles sont interdits par défaut ou cloisonnés par utilisateur et version de droit. Une réponse RAG privée ne peut être réutilisée pour un autre lecteur. Les journaux masquent tokens, liens signés et champs sensibles.

### Données et gouvernance

Collecter seulement identité de connexion, préférences utiles et preuves nécessaires. Documenter finalités, prestataires, localisation, conservation et procédure d'export ou suppression. Les durées proposées au départ sont 30 jours pour les traces IA détaillées et 90 jours pour les conversations inactives, à valider avant pilote. Les pièces financières suivent une politique distincte validée selon les obligations applicables.

Informer l'utilisateur des traitements IA et des données transmises aux fournisseurs. Fournir un contact pour les demandes de données et les réclamations. Les catégories jeunesse ne doivent pas introduire de comptes mineurs autonomes sans cadrage spécifique ; les achats restent effectués par des adultes au MVP.

### Validation commerciale

La licence des contenus, les contrats éditeurs, la confidentialité, les taxes et les règles de consommation doivent être examinés avant lancement. JWT, RBAC, chiffrement ou un agent « juridique » ne prouvent pas à eux seuls une conformité réglementaire.

# 19 Architecture technique et déploiement

### Composants retenus

| Composant | Choix proposé | Responsabilité |
|---|---|---|
| Frontend | React, TypeScript, Vite sur Vercel | Pages, formulaires, lecteur et suivi des tâches |
| API | FastAPI, Pydantic, SQLAlchemy sur Render | Identité, commerce, accès et propositions |
| Orchestration | LangGraph dans un worker Python | Coordination, checkpoints et reprises |
| MCP | SDK Python, Streamable HTTP | Catalogue, abonnements et support |
| Base | PostgreSQL managé | Source de vérité métier et états persistants |
| File et quotas | Redis compatible, persistance adaptée | Distribution de tâches et limites de débit |
| Documents | Stockage objet privé | Fichiers, extraits et versions |
| Recherche | Qdrant managé au départ | Index documentaire reconstruisible |
| Modèles | Fournisseur API interchangeable | Génération et embeddings |

### Flux d’exécution

Le navigateur communique avec FastAPI ; FastAPI enregistre la demande et son événement. Le worker récupère la tâche, restaure le checkpoint et coordonne les agents. Ceux-ci utilisent les clients MCP. Les serveurs MCP appellent les mêmes services métier que REST. Les événements persistés alimentent le statut et le flux d’interface.

Les trois routes MCP peuvent être montées dans le même déploiement backend au MVP, avec cycle de vie ASGI testé. Si la dépendance choisie ne le permet pas correctement, créer un service MCP dédié partageant les bibliothèques métier. Ne pas multiplier les services uniquement pour imiter un organigramme d’agents.

### Déploiements

INF01 P0 : environnements local, staging et production isolés, secrets distincts et versions verrouillées. CI : lint, types, tests, migrations de test, build frontend et image backend. Déployer d’abord sur staging ; effectuer les migrations puis la vérification des parcours essentiels.

INF02 P0 : aucun fichier critique dans un filesystem éphémère. Les modèles locaux lourds et l’hébergement d’Odoo sont exclus. Les traitements longs restent sur le worker ; les fonctions Vercel ne portent pas la coordination complète [R4, R5].

INF03 P1 : choisir une région cohérente pour API, base, file et index afin de limiter la latence. Ne pas supposer la compatibilité des extensions PostgreSQL ou des limites d’offre : les vérifier avant provisioning. Les tarifs et capacités sont à revalider au déploiement.

### Configuration

Prévoir DATABASE_URL, QUEUE_URL, OBJECT_STORAGE_*, VECTOR_STORE_*, LLM_PROVIDER, MODEL_ID, EMBEDDING_MODEL, MCP_SERVER_URLS, AUTH_*, CORS_ORIGINS et PAYMENT_*. Les valeurs secrètes restent dans les gestionnaires des hébergeurs. Les domaines et certificats HTTPS sont configurés avant exposition publique.

# 20 Fiabilité et procédures d’exploitation

### Tâches et reprise

OPS01 P0 : PostgreSQL conserve le job et son état ; la file accélère son traitement mais ne constitue pas l’unique preuve de son existence. Utiliser une outbox transactionnelle pour éviter de perdre une tâche après un commit métier. Le worker réclame un job avec un bail renouvelable ; une tâche abandonnée est récupérable après expiration du bail.

OPS02 P0 : retry avec délai croissant et jitter pour les erreurs transitoires ; aucun retry aveugle d’une écriture externe. Réutiliser les identifiants d’idempotence et vérifier l’état distant lorsqu’un résultat est inconnu. Après le maximum de tentatives, placer en échec visible avec procédure de reprise.

### Dépendances indisponibles

| Incident | Comportement attendu |
|---|---|
| Modèle indisponible | Parcours classiques disponibles ; message clair et tâche relançable |
| Serveur MCP en panne | Pas de résultat inventé ; retour partiel ou escalade |
| Index vectoriel indisponible | Recherche publique alternative si sûre ; aucune conclusion contractuelle sans preuve |
| File indisponible | Tâche persistée en attente ; pas de fausse exécution |
| Paiement incertain | Commande en attente et réconciliation ; aucun double débit volontaire |
| Base indisponible | Refus des mutations, erreur maîtrisée et alerte |

### Sauvegardes et restauration

OPS03 P1 : sauvegarder la base quotidiennement, activer une restauration plus fine si disponible et adaptée au budget ; versionner les fichiers et sauvegarder les configurations sans exposer leurs secrets. Les index doivent être reconstruisibles depuis les documents autorisés.

Objectifs initiaux proposés pour le pilote : perte de données maximale de 24 heures et rétablissement en quatre heures. Ils restent des cibles internes à tester, pas un SLA client. Un pilote payant peut exiger des objectifs plus stricts. Effectuer une restauration dans un environnement isolé avant ouverture et au moins trimestriellement ensuite.

### Incidents et retour arrière

Conserver un guide pour compromission de secret, paiement dupliqué, contenu divulgué, index incohérent et boucle d’agent. Pouvoir désactiver les mutations IA tout en gardant le catalogue disponible. Chaque incident possède responsable, heure, impact, actions, preuve de résolution et mesure préventive.

Un rollback applicatif ne rembobine pas un paiement externe. Les migrations destructrices sont différées ; appliquer d'abord des changements compatibles. Les comptes de démonstration et outils de reset sont absents de la production commerciale.

# 21 Observabilité et exigences non fonctionnelles

### Mesures obligatoires

OBS01 P0 : corréler request_id, run_id, step_id, tool_call_id, action_id et order_id. Tracer statut, latence, modèle, version de prompt, tokens réels lorsqu'ils sont disponibles et coût estimé à partir d'un tarif versionné. Identifier explicitement les estimations ; ne pas les présenter comme la facture fournisseur.

OBS02 P0 : tableau de bord pour réussite par parcours, erreurs par outil, tâches bloquées, propositions expirées et actions refusées. Les traces de démonstration ne sont pas mélangées aux métriques du pilote.

### Cibles de recette proposées

| Mesure | Cible initiale | Conditions de mesure |
|---|---|---|
| Catalogue API | p95 inférieur à 800 ms | 50 lectures concurrentes, 1 000 éditions, cache documenté |
| Écriture métier hors paiement | p95 inférieur à 1,5 s | 10 écritures concurrentes, PostgreSQL réel |
| Accusé de tâche IA | inférieur à 2 s au p95 | Service déjà démarré, tâche persistée |
| Réponse IA simple | p95 inférieur à 20 s | Modèle et région indiqués, corpus de référence |
| Parcours multi-agent | p95 inférieur à 60 s | Hors approbation et paiement humains |
| Disponibilité pilote | objectif interne 99,5 % mensuel | Mesure externe, incidents documentés |
| Isolation | zéro fuite dans les tests | API, MCP, index, fichiers et cache |

### Ressources et budgets

NFR01 P0 : plafonds par utilisateur, run et période ; contrôle du budget avant nouvel appel. La limite de concurrence des workers protège le fournisseur LLM et la base. Afficher une erreur compréhensible en cas de quota et conserver la tâche sans boucle de retry infinie.

NFR02 P1 : alerter sur jobs en attente anormale, erreurs de paiement, coût IA journalier dépassé, absence de sauvegarde et échec de contrôle de santé. Définir les seuils après une semaine de mesure ; ne pas utiliser une valeur universelle pour toutes les dépendances.

### Qualité de service

Documenter les démarrages à froid et les dépendances du plan d'hébergement. Une offre gratuite en veille n'est pas adaptée à un engagement de disponibilité sans analyse. Les objectifs de performance ne doivent pas être atteints en supprimant l'authentification, les filtres d'accès ou la persistance.

Le frontend présente un état d'attente et permet l'annulation. L'arrêt d'un run interrompt les appels futurs ; une opération externe déjà engagée passe par une vérification ou compensation explicite.

# 22 Stratégie de tests et évaluation IA

## Niveaux de tests

Les tests unitaires couvrent les règles de prix, périmètres, états et permissions. Les tests d'intégration utilisent PostgreSQL réel pour les transactions et contraintes, un stockage de test et les vrais contrats MCP. Les tests E2E parcourent l'interface jusqu'au résultat persisté. Les adaptateurs externes disposent de tests simulés et, avant pilote, d'une validation en environnement prestataire.

## Jeu d'évaluation initial

Préparer 80 scénarios versionnés : 15 recommandations, 15 accès et abonnements, 10 conditions documentaires, 10 demandes composées, 10 demandes ambiguës ou non couvertes, 10 attaques ou accès interdits et 10 échecs de dépendances. Chaque cas précise données initiales, acteur, résultat autorisé, sources attendues et effets interdits.

Comparer un workflow fixe, un agent unique avec outils et la version multi-agent sur les mêmes cas et budgets. Répéter les cas critiques pour observer la variabilité. Les jugements automatiques sont calibrés sur une revue humaine ; un LLM juge ne valide pas seul une mutation ou une règle d'autorisation.

## Critères IA proposés

| Mesure | Seuil de départ | Méthode |
|---|---|---|
| Réussite des cas nominaux | au moins 90 % | Objectif atteint et état métier correct |
| Validité des références citées | 100 % | Document et passage existants, accessibles |
| Appui factuel sur les cas sourcés | au moins 95 % | Revue de l'assertion et du passage |
| Mutation non autorisée | zéro | Inspection des événements et de la base |
| Clarification ou refus attendu | au moins 90 % | Cas ambigus et hors corpus |
| Action annoncée sans preuve | zéro sur cas critiques | Comparaison réponse et effet persistant |

## Régressions

TEST01 P0 : chaque modification de prompt, modèle, schéma d'outil ou politique d'accès déclenche les tests concernés. Les tests rapides utilisent des réponses stables ; un sous-ensemble live à budget borné est exécuté avant release significative.

TEST02 P0 : conserver résultats bruts, versions, coût, latence et erreurs ; ne pas sélectionner uniquement les conversations réussies. Tout échec d'isolation, paiement ou double exécution bloque la livraison même si le score moyen est élevé.

### Limites

Les seuils sont des objectifs à ajuster après baseline documentée. Réussir 80 scénarios ne prouve pas une sécurité absolue ni une qualité sur toutes les langues. Les métriques doivent être ventilées par parcours, langue et type d'erreur, avec le nombre de cas associé.

# 23 Recette fonctionnelle et traçabilité

### Cas indispensables

| Test | Exigences | Résultat attendu |
|---|---|---|
| T01 Catalogue public | CAT01 à CAT04 | Recherche utilisable ; aucun brouillon ou fichier privé visible |
| T02 Achat de test | PAY01, PAY02, SUB02 | Commande, paiement et accès cohérents |
| T03 Événement répété | PAY05, CON04, CON05 | Un seul effet métier et une seule activation |
| T04 Dernière place | CON01 à CON03 | Une réussite sur 100 demandes concurrentes |
| T05 Expiration et paiement | PAY06, CON02 | État cohérent ou exception explicite, sans double restitution |
| T06 Isolation | IAM01 à IAM04, SEC03 | Aucun accès croisé lecteur ou éditeur |
| T07 Parcours composé | AG01 à AG07 | Deux spécialistes au minimum avec dépendance observable |
| T08 Injection documentaire | SAFE01 à SAFE05 | Aucun outil interdit ou changement de permission |
| T09 Proposition périmée | SUB06, SAFE03 | 409 et nouvelle proposition à confirmer |
| T10 Reprise worker | OPS01, OPS02 | Tâche reprise, effets déjà exécutés non dupliqués |
| T11 Résiliation | SUB05 | Fin d'accès à la date prévue, historique préservé |
| T12 Retrait de contenu | CAT07, RAG03 | Plus de vente ni recherche non autorisée |
| T13 Contrat MCP | MCP01, MCP02 | Découverte, appel, refus et erreurs vérifiés |
| T14 Parcours mobile | UX01 à UX06 | Catalogue, confirmation et bibliothèque utilisables |
| T15 Sauvegarde pilote | OPS03 | Restauration et contrôle des dossiers réussis |

### Conditions de livraison

Tous les P0 sont réalisés et leurs tests passent. Aucun défaut critique ou majeur connu ne concerne données personnelles, droits, paiement, concurrence ou actions IA. Les défauts mineurs résiduels ont une description, un responsable et une échéance. La recette est effectuée sur staging avec la version exacte à déployer.

Les modes mock, sandbox et live sont identifiables dans l'administration et dans les parcours de démonstration. Une fonctionnalité non raccordée n'est pas présentée comme active. L'installation depuis un dépôt propre et la reconstruction de l'index sont documentées et vérifiées.

### Livrables de réalisation

Dépôt versionné, README français et anglais, schéma des données, migrations, contrats OpenAPI et MCP, jeux de données fictives, tests, jeu d'évaluation, décisions d'architecture, procédures de déploiement et incident, rapport de recette et démonstration enregistrée.

La recette du pilote ajoute paiement réel autorisé, droits éditoriaux vérifiés, authentification renforcée des administrateurs, sauvegarde restaurée et politique de traitement des données validée. La signature de recette enregistre porteur, version, date, réserves et décision de mise en service.

# 24 Plan de réalisation et jalons

### Estimation de travail

L'estimation suivante suppose un développeur connaissant React, FastAPI et PostgreSQL, utilisant des API de modèles et des contenus de démonstration. Elle ne comprend pas l'attente de contrats éditeurs, de vérification de paiement ou de validation juridique. Les charges seront réévaluées après le premier prototype MCP.

| Lot | Charge indicative | Livrable et condition de sortie |
|---|---|---|
| L0 Cadrage | 3 à 5 jours | Règles produit, maquettes et décisions ouvertes |
| L1 Socle | 5 à 8 jours | Authentification, données, migrations et déploiement vide |
| L2 Catalogue et accès | 7 à 10 jours | Contenus publiés, offres et bibliothèque protégée |
| L3 Commerce fiable | 7 à 10 jours | Paiement de test, idempotence et test de concurrence |
| L4 Outils MCP et RAG | 6 à 9 jours | Trois contrats MCP, sources et filtres vérifiés |
| L5 Multi-agent | 8 à 12 jours | Coopération, confirmations, checkpoints et reprise |
| L6 Recette et démo | 6 à 9 jours | E2E, évaluations, corrections et documentation |

### Lecture du calendrier

Total indicatif : 42 à 63 jours de travail, avant marge. Prévoir 20 % de réserve pour intégrations et corrections, soit environ 50 à 76 jours. À temps plein, cela représente approximativement 10 à 16 semaines ; à temps partiel, le calendrier s'allonge. Il s'agit d'un cadrage initial, pas d'un engagement ferme.

La dépendance critique suit L0 → L1 → L2 → L3 → L4 → L5 → L6. Les maquettes et les tests peuvent progresser en parallèle des services concernés. Le catalogue et les achats classiques doivent fonctionner avant de confier ces actions aux agents.

### Démonstrations par jalon

J1 : rechercher une publication et ouvrir un extrait. J2 : acheter en test et obtenir un accès. J3 : appeler les mêmes fonctions via MCP avec refus d'accès vérifié. J4 : résoudre une demande composée, puis confirmer une action. J5 : provoquer une panne, reprendre et présenter les mesures.

### Gestion du changement

Toute demande nouvelle reçoit une priorité, une charge, un impact sur sécurité, données, tests et exploitation. Si elle modifie un invariant ou une promesse commerciale, mettre à jour le cahier des charges avant développement. Les modules P2 ne doivent pas retarder les corrections d'intégrité du MVP.

Réduire en premier les formats, catégories ou variantes d'offres si le temps manque. Conserver les contrôles d'accès, l'idempotence, les tests de concurrence et la distinction entre action préparée et exécutée.

# 25 Élargissement progressif du produit

### Étapes après le MVP

| Étape | Extension | Condition avant activation |
|---|---|---|
| Pilote | Quelques lecteurs et éditeurs partenaires | Recette P0, droits et paiement validés, assistance disponible |
| Offre enrichie | Audio, anglais, malgache, cadeaux | Droits adaptés, stockage et tests linguistiques |
| Organisations | Sièges, invitations et contrats collectifs | Modèle d'appartenance, révocation et facturation testés |
| Éditeurs autonomes | Dépôt, modération et statistiques | Isolation, revue éditoriale et droits de distribution |
| Commerce étendu | Récurrence, promotions, multi-devise | Prestataire compatible et simulations financières fiables |
| Écosystème | Clients MCP externes et partenaires | Autorisation déléguée, quotas et contrats versionnés |

### Évolutions métier

L'audio demande métadonnées de durée, transcription autorisée et lecteur accessible. La vidéo ajoute encodage, bande passante et droits spécifiques. Les cadeaux nécessitent codes à usage unique, expiration et gestion du bénéficiaire. Les organisations exigent des accès nominatifs ; un abonnement collectif ne doit pas être traduit par un mot de passe partagé.

Les reversements éditeurs constituent un chantier distinct : contrat, base de calcul, corrections, taxes et rapprochement. Commencer par un reporting contrôlé et des règlements manuels documentés avant d'automatiser. La presse papier ajoute stock, livraison, adresses et retours ; elle n'est pas une simple option de format.

### Évolutions IA

Ajouter un agent assistance lorsque les tickets démontrent un besoin. Un agent éditorial destiné aux partenaires peut aider à rédiger des métadonnées, sous validation humaine. Un agent d'analyse commerciale peut produire des synthèses agrégées sans accéder aux données personnelles inutiles. Chaque nouvel agent est comparé à une extension du système existant avant adoption.

Introduire une recommandation personnalisée uniquement après consentement et disponibilité de données utiles. Mesurer diversité, pertinence et exposition des éditeurs ; séparer contenu sponsorisé et classement

organique. Aucune optimisation des ventes ne doit cacher un abonnement déjà détenu ou pousser une offre incompatible.

### Montée en charge

Séparer API, MCP ou services métier lorsque les profils de charge, exigences de sécurité ou responsabilités l'exigent. Mesurer avant d'ajouter une infrastructure complexe. Prévoir caches publics, files distinctes pour ingestion et agents, limites par éditeur et index adaptés. Les migrations préservent les historiques de contrats et les clients MCP existants via versionnement.

Aucune date d'extension n'est imposée avant les résultats du pilote. Une phase est autorisée par ses critères de sortie, les retours utilisateurs et le budget disponible.

# 26 Budget risques et arbitrages

### Budget à construire

| Poste | Facteur de coût | Mesure de maîtrise |
|---|---|---|
| API et worker | Instances, RAM, disponibilité | Mesurer charge et séparer les tâches lourdes |
| Base et file | Volume, sauvegardes, connexions | Index, pools bornés et rétention |
| Stockage et diffusion | Taille des fichiers et téléchargements | Extraits légers et politique de cache adaptée |
| Modèles IA | Tokens, appels, modèles et tentatives | Budgets par run, contexte ciblé et mesures |
| Recherche documentaire | Index, embeddings et réindexations | Ingestion incrémentale et déduplication |
| Paiement et communication | Frais, emails et messages | Choix prestataire et suivi des opérations |
| Exploitation | Domaine, supervision et maintenance | Inventaire et revue mensuelle |

### Modèle de calcul

Budget mensuel = coûts fixes d'infrastructure + stockage et trafic + consommation IA + frais de paiement et communication. Coût IA d'un parcours = somme des tokens d'entrée et de sortie valorisés aux tarifs du modèle, plus embeddings et appels externes facturés. Suivre médiane et p95 par parcours ; ne pas multiplier un coût de chatbot simple par un nombre d'utilisateurs sans mesurer les agents.

Aucun tarif actuel n'est fixé dans ce document. Produire un devis daté avant provisioning et des plafonds d'alerte. Le budget de développement doit aussi valoriser le temps de conception, recette et maintenance ; une plateforme fonctionnelle ne garantit pas sa rentabilité.

### Risques principaux

| Risque | Impact | Réponse prévue |
|---|---|---|
| Catalogue sans droits suffisants | Blocage de diffusion | Contenus autorisés et registre des contrats |
| Prestataire indisponible pour le marchand | Blocage commercial | Adaptateur interchangeable, validation anticipée |
| Trop de modules simultanés | Retard et défauts | Trois parcours P0, extensions après recette |
| Hallucination d'action ou de condition | Perte de confiance | Résultats typés, preuves et validations serveur |
| Coûts IA élevés | Exploitation non viable | Limites, comparaison agent unique et multi-agent |
| Fuite entre éditeurs ou lecteurs | Incident critique | Filtres, tests, audit et arrêt des fonctions touchées |
| Faible intérêt utilisateur | Produit peu utilisé | Entretiens, pilote et décisions basées sur retours |

### Décisions encore ouvertes

Avant L1 : nom, formats, règles d'achat et public exact. Avant L3 : unité monétaire, durée d'accès, renouvellement et quotas. Avant pilote : éditeurs partenaires, statut commercial, prestataire, contrats, conservation des données et budget d'exploitation. Avant expansion : langues, nouveaux formats et modèle économique des partenaires.

# 27 Références et glossaire

### Références techniques

Les références ci-dessous ont été consultées le 30 septembre 2026. Elles décrivent des mécanismes techniques ; elles ne valident pas le produit, les droits éditoriaux ou l'éligibilité d'un marchand. Les versions réellement utilisées seront figées dans le dépôt et revalidées lors des mises à jour.

[R1] Model Context Protocol — Architecture et interfaces de serveurs.

https://modelcontextprotocol.io/docs/learn/architecture

Usage : séparation hôte, clients et serveurs ; exposition des outils et transport distant. Le SDK doit respecter la version de protocole retenue.

[R2] LangGraph — Persistence.

https://docs.langchain.com/oss/python/langgraph/persistence

Usage : checkpoints et reprise de l'état. Les effets externes exigent toujours une idempotence métier.

[R3] PostgreSQL — Transaction Isolation.

https://www.postgresql.org/docs/current/transaction-iso.html

Usage : concurrence, visibilité des transactions et traitement des conflits. Les tests de quota utilisent PostgreSQL réel.

[R4] Render — Background Workers.

https://render.com/docs/background-workers

Usage : séparation des tâches longues et des requêtes interactives.

[R5] Vercel — Functions Limits.

https://vercel.com/docs/functions/limitations

Usage : contraintes d'exécution à vérifier lors du déploiement ; orchestration longue confiée au worker.

[R6] Stripe — Webhooks.

https://docs.stripe.com/webhooks

Usage : exemple de notifications vérifiées et de traitement des événements. Ne constitue pas une recommandation d'éligibilité commerciale à Madagascar.

## Glossaire

| Terme | Définition dans ce projet |
|---|---|
| MCP | Protocole d'accès à des outils et ressources ; distinct de l'orchestration des agents |
| RAG | Recherche de passages avant génération d'une réponse sourcée |
| Entitlement | Droit technique, limité par son périmètre et sa période |
| Idempotence | Répéter la même opération ne répète pas son effet métier |
| Outbox | Événement enregistré avec la transaction puis transmis après commit |
| Checkpoint | État enregistré permettant de reprendre un traitement |
| p95 | Valeur en dessous de laquelle se situent 95 % des observations |
| P0 P1 P2 | MVP indispensable, pilote, puis extension |

## Statut de validation

Version proposée à relire par le porteur du projet. Le démarrage du développement n'autorise pas à lui seul une diffusion de contenus tiers, un paiement réel ou une publication commerciale. Les décisions ouvertes de la section 26 doivent être résolues aux jalons indiqués.